

第 5 章 SQL

数据完整性

约束类型

约束检查

其他约束形式

约束的对象级别

- **列级约束**

- 列值范围

- **行级约束**

- 同一行各列之间

- **表级约束**

- 行间、表上、表间

分析下面约束的对象级别

- sno要求是8位整数，首位是0或1
- 飞行员的星级评定取决于其飞行里程
- 选课人数不能少于10人，多于100人
- 在本地纳税记录超过5年才有购房资格

约束类型

- **primary key**
- **foreign key**
- **unique**
- **default**
- **not null**
- **check**

这些约束的对象级别分别是什么？

存储约束的系统表: **sysconstraints**

列名	数据类型	描述
constid	int	约束号
id	int	拥有该约束的表 ID
colid	smallint	在其上定义约束的列 ID，如果是表约束则为 0
status	int	位图指示状态。可能的值包括： 1 = PRIMARY KEY 约束 2 = UNIQUE KEY 约束 3 = FOREIGN KEY 约束 4 = CHECK 约束 5 = DEFAULT 约束 16 = 列级约束 32 = 表级约束

约束命名及其定义

constraint 约束名 <约束条件>

撤消约束: alter table...drop constraint...

添加约束: alter table...add constraint...

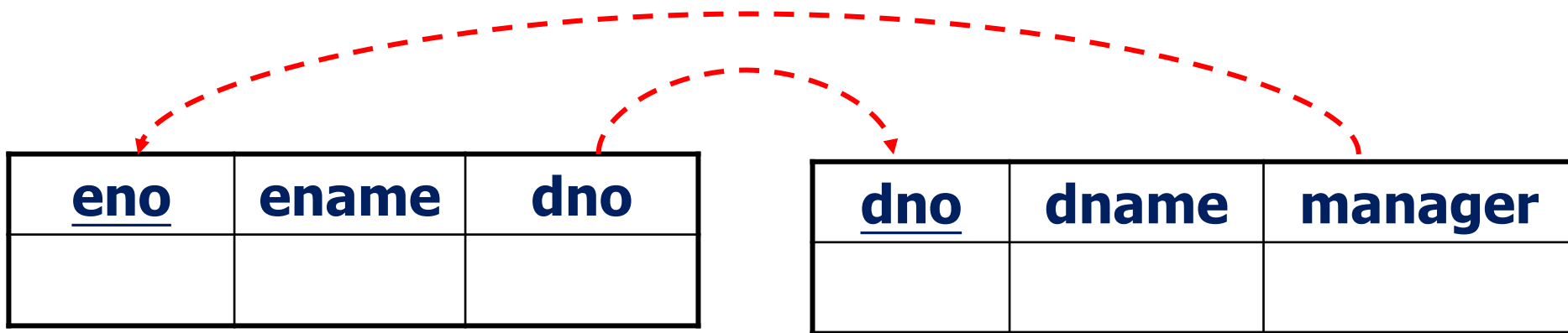
alter table student **add constraint**

Gender_Check check(gender in (' M' , ' F'))

alter table student **drop constraint** **Gender_Check**

约束命名及其定义

如何定义两个相互参照的表？



- ① create table emp(eno primary key...)
- ② create table dept(dno primary key, manager foreign key...)
- ③ alter table emp **add constraint** dno foreign key...

primary key 与 unique

- 都是通过唯一性索引来支持，它们有何区别？
- 一个带有唯一性声明的属性（组）上有多少个null？

create table check_unique (

col1 int **unique**,

col2 int,

col3 int,

unique (col2, col3))

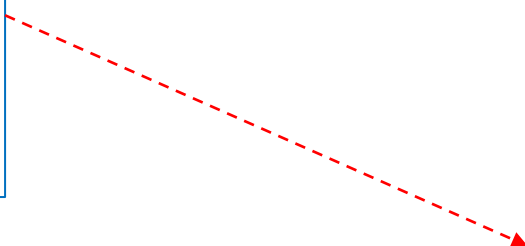
Col1	Col2	Col3
1	3	4
2	5	null
null	6	null

leader(teacher_no, project_no, start_time)

如何表达：每位老师在一定时间内只能负责一个项目？

primary key 与 unique 的背后

```
select *  
  
from INFORMATION_SCHEMA.table_constraints  
  
where table_name = 'check_unique'
```



CONSTRAINT_NAME	TABLE_SCHEMA	TABLE_NAME	CONSTRAINT_TYPE
col1	my_db	check_unique	UNIQUE
col2	my_db	check_unique	UNIQUE

```
select *  
  
from INFORMATION_SCHEMA.innodb_indexes  
  
where table_id=1225
```



INDEX_ID	NAME	TABLE_ID	TYPE
360	GEN_CLUST_INDEX	1225	1
361	col1	1225	2
362	col2	1225	2

foreign key

基本关系：主码所在的关系

依赖关系：外码所在的关系

- 为保证参照完整性，仅仅监视依赖关系上的修改操作是不完备的
- 如果基本关系中的行可以随意修改也会破坏参照完整性

sno	sname	dno
s1	Tom	d1
s2	Bob	d2

dno	dname
d1	CS
d2	MATH



sno	sname	dno
s1	Tom	d1
s2	Bob	d2

dno	dname
d2	MATH

foreign key: 三种定义方式

- **RESTRICT**方式: 只有当依赖关系中没有一个外码值与要删除 (更新) 的基本关系的主码值相对应时, 才可以删除 (更新) 该行 (的主码), 否则系统拒绝该操作
- **CASCADE**方式: 将依赖关系中所有外码值与基本关系中要删除的主码值所对应的行一起删除 (将依赖关系中所有与基本关系中要修改的主码值所对应的外码值一起修改为新值)
- **SET NULL**方式: 删除 (更新) 基本关系中的行时, 将依赖关系中与基本关系中被删 (更新) 主码值相对应的外码值置为空值

伐冰之家 不畜牛羊

delete d1

sno	sname	dno
s1	Tom	d1
s2	Bob	d2

dno	dname
d1	CS
d2	MATH

on delete RESTRICT

sno	sname	dno
s1	Tom	d1
s2	Bob	d2

dno	dname
d1	CS
d2	MATH

on delete CASCADE

sno	sname	dno
s2	Bob	d2

dno	dname
d2	MATH

on delete SET NULL

sno	sname	dno
s1	Tom	null
s2	Bob	d2

dno	dname
d2	MATH

表级约束：涉及多行或多表之间的影响

```
create table SC (  
    sno    char(8),  
    cno    char(10),  
    grade  smallint,  
    primay key (sno, cno),  
    check( sno in (select sno from student) ),  
    check( cno in (select cno from course) ) )
```

- 上述的check定义是否等价于外码约束？
- 如果student中删除行，不会触发check检查，只有SC表的更新才会触发

断言 **assertion** : not exists

create assertion AtoB check

(not exists

(select A

from R

group by A

having count (distinct B) > 1)

)

这个断言所维护
的约束是什么?

很多数据库不支持断言，以及带子查询的check，怎么办？

函数约束：要求每门课的选课人数不能多于100人

```
create function fn_registerCount ( @cno varchar )  
  
returns int as  
  
begin  
  
return  
  
    (select count(*)  
  
    from    sc  
  
    where cno = @cno )  
  
End
```

为表sc列添加如下check约束：

```
alter table sc add constraint CK_registerCount check ( fn_registerCount(cno) <= 100 )
```

函数约束：要求优先使用最小的空缺序列号

noGap(no int **primary key**, name varchar(10))

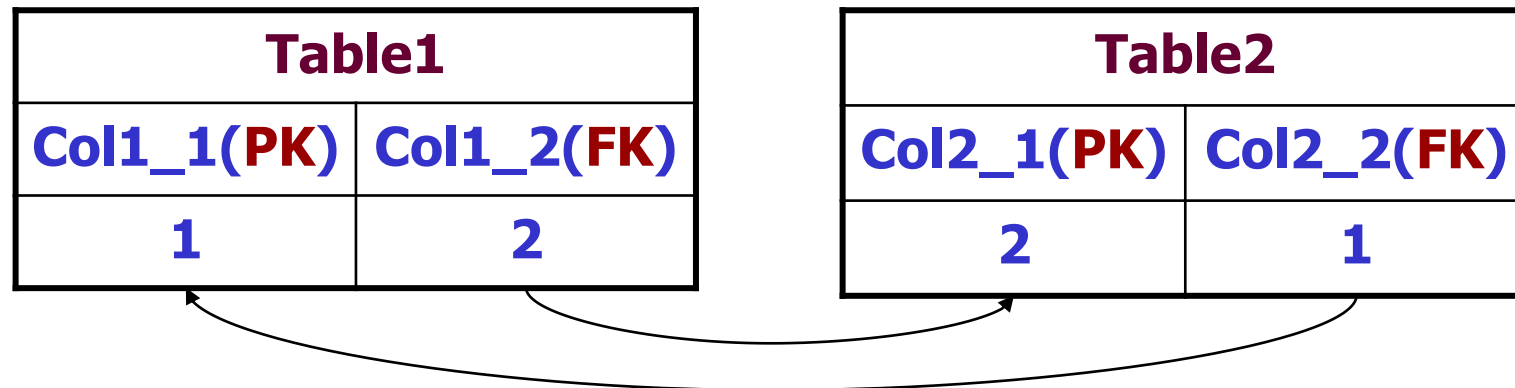
```
create function fn_noGap_minUnusedKey()
returns int as
begin
    if ( not exists ( select * from noGap where no = 1 )) return 1
    declare @min_unused_no int
    select    @min_unused_no = min(no + 1)
    from      noGap NO1
    where     not exists
              (select *
               from   noGap NO2
               where   NO2.no = NO1.no+1)
    return @min_unused_no
end
```

alter table noGap **add constraint** DF_no **default** (fn_noGap_minUnusedKey ()) **for** no

约束检查

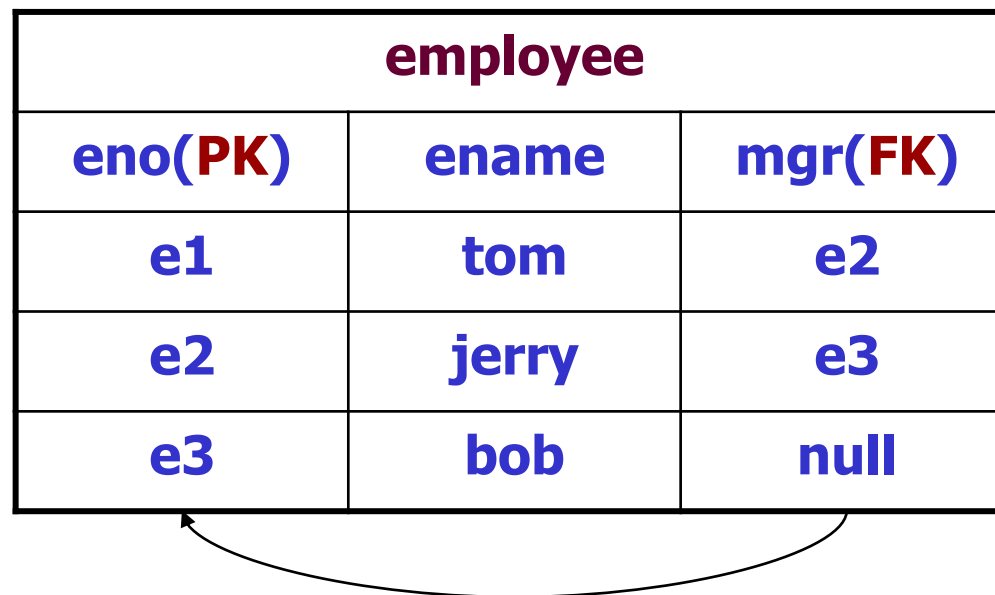
互参照表

相互参照的表，
如何插入行？



自参照表

如何往自参照的表里
批量插入数据？



标准SQL中的延迟约束

延迟约束

deferred constraints

- 将多个更新操作语句放入一个事务，在提交时才检查约束

如何设置延迟约束？

在约束创建时：

[not] deferrable

initially deferred [immediate]

对现有约束：

set constraint 约束名 deferred

延迟约束检查

```
create table emp(  
    eno          char(10) primary key,  
    ename        char(20),  
    mgr          char(10)  
    constraint FK_Constraint foreign key references emp(eno)  
    deferrable initially immediate
```

设置延迟约束: `set constraint FK_Constraint deferred`

SQL Server的约束开关

添加未验证的约束(**with nocheck**)

```
create table t1 (col_a INT)
```

```
insert into t1 values (-1)
```

```
alter table t1 with nocheck add constraint skip_check check (col_a > 1)
```

```
insert into t1 values (-2)
```

禁用并重新启用一个约束(**nocheck**)

```
alter table t1 nocheck constraint skip_check
```

```
insert into t1 values (-2)
```

```
alter table t1 check constraint skip_check
```

dbcc checkconstraints

Table	Constraint	Where
t2	skip_check	col_a = '-1'
t2	skip_check	col_a = '-2'



第 5 章

数据库安全性

主体

客体

权限

角色

审计

加密

SQL注入

统计数据库安全

隐私保护

制度决定论：制定时有罪推定 审判时无罪推定

准入：合法用户，身份鉴定，标识 + 口令

权限：存取范围，只能干什么 VS 不能干什么

配额：资源控制，粮票、阶梯水费、DOS、DDOS

审计：无处不在的探头，一切皆有案底

加密：雾里看花花非花，我知道你不知道

主体

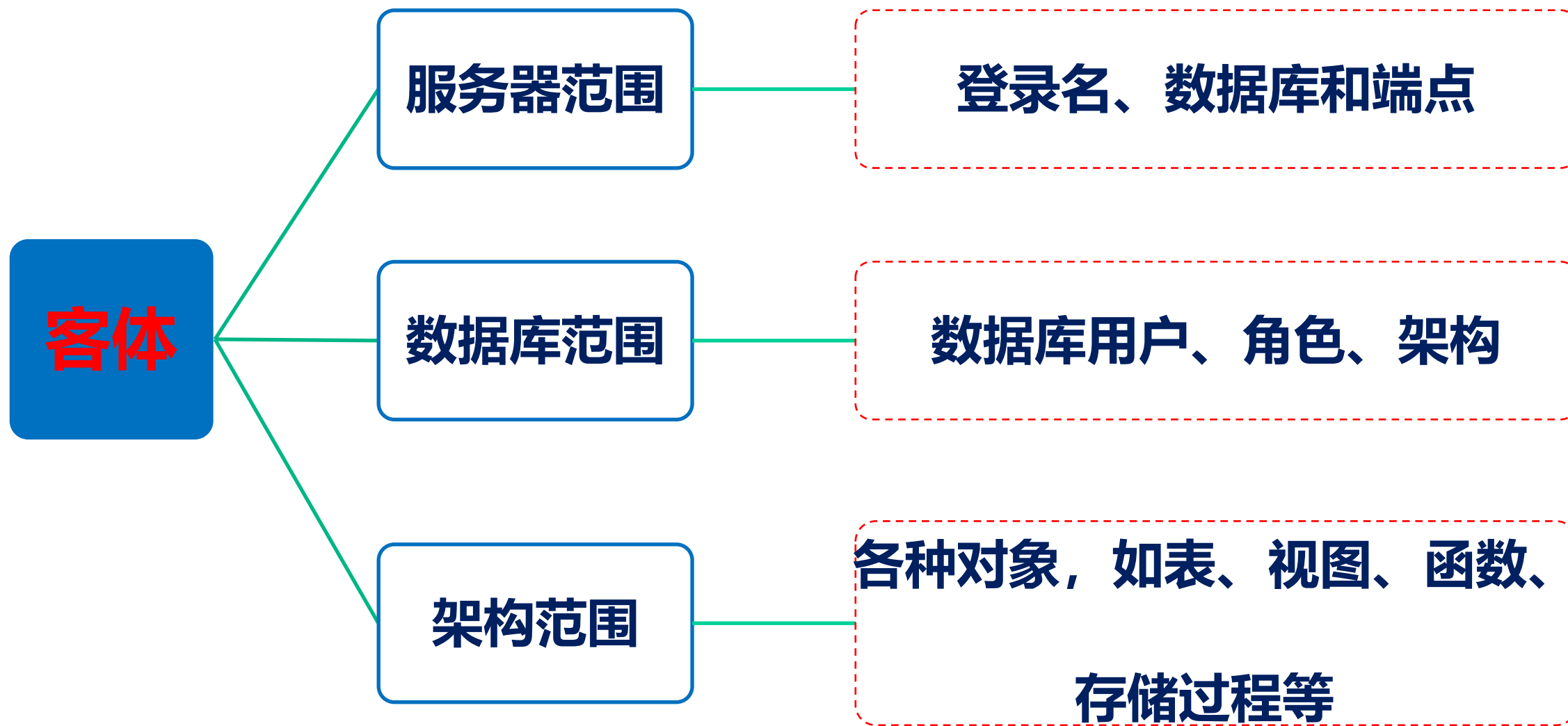
**主体(principal): 是可以授予权限以访问特定数据库对象的对象
包括登录用户、角色、应用程序**

创建数据库用户:

create user user_name

**create user Carefully
for login [ljchen-PC\SQLUser]
with default_schema = Finance**

客体：安全对象(securable)



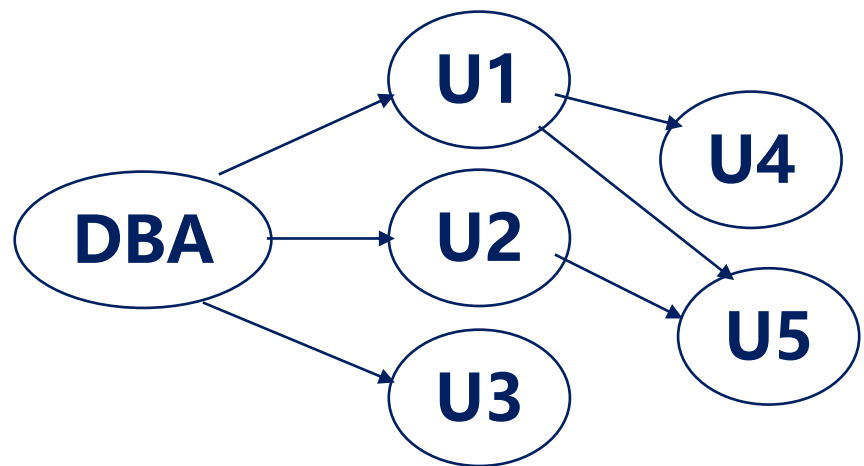
权限

- 权限(permission): 允许主体在安全对象上执行操作
- 权限的转授和回收: 允许用户把已获得的权限转授给其他用户, 或者把已授给其他用户的权限再回收上来

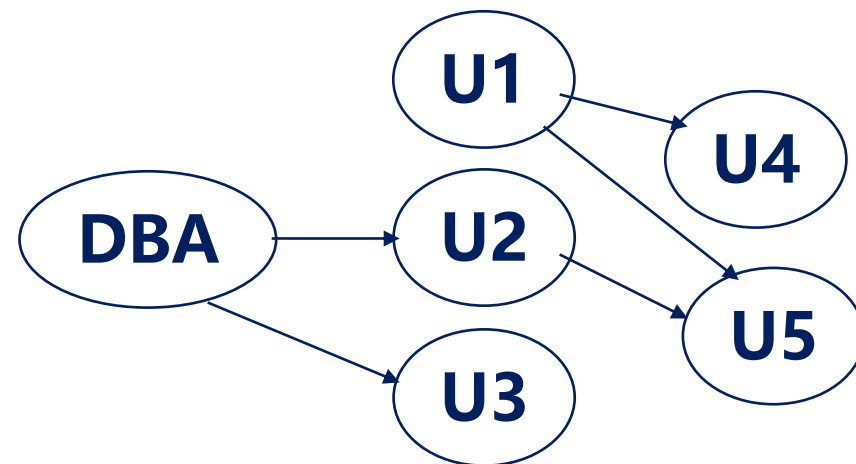
权限图: 结点为用户, 根结点是 DBA

- 有向边 $U_i \rightarrow U_j$, 表示用户 U_i 把某权限授给用户 U_j
- 一个用户拥有权限的充分必要条件是在权限图中有一条从根结点到该用户结点的路径

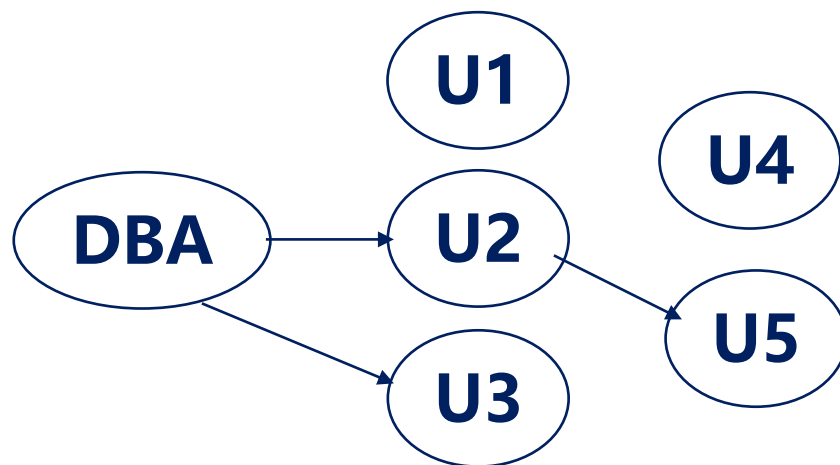
授权图



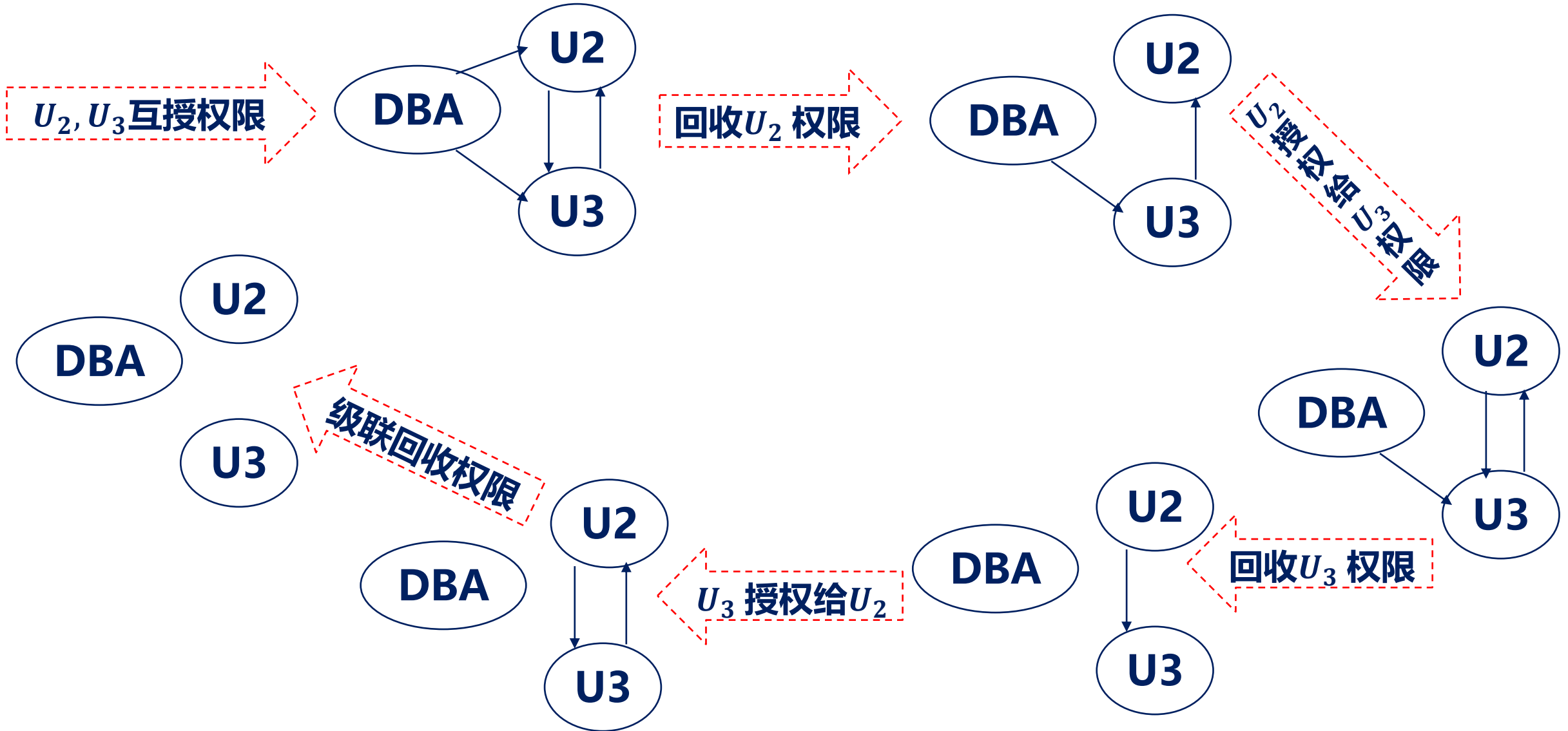
回收 U_1 权限



回收用户U1



授权图要始终保证授权路径起点是DBA



授权命令

grant

权限

on

对象名

to

{用户 [, 用户]... | public}

[with grant option]

with grant option

获得权限的用户可以把
权限再授予其它用户

表级权限: select, update, insert, delete, index,
alter, drop, resource等以及它们的总和all

为什么需要references权限?

回收权限

revoke	权限
on	对象
from	{用户 [, 用户]... public}

授权路径的起点一定是DBA

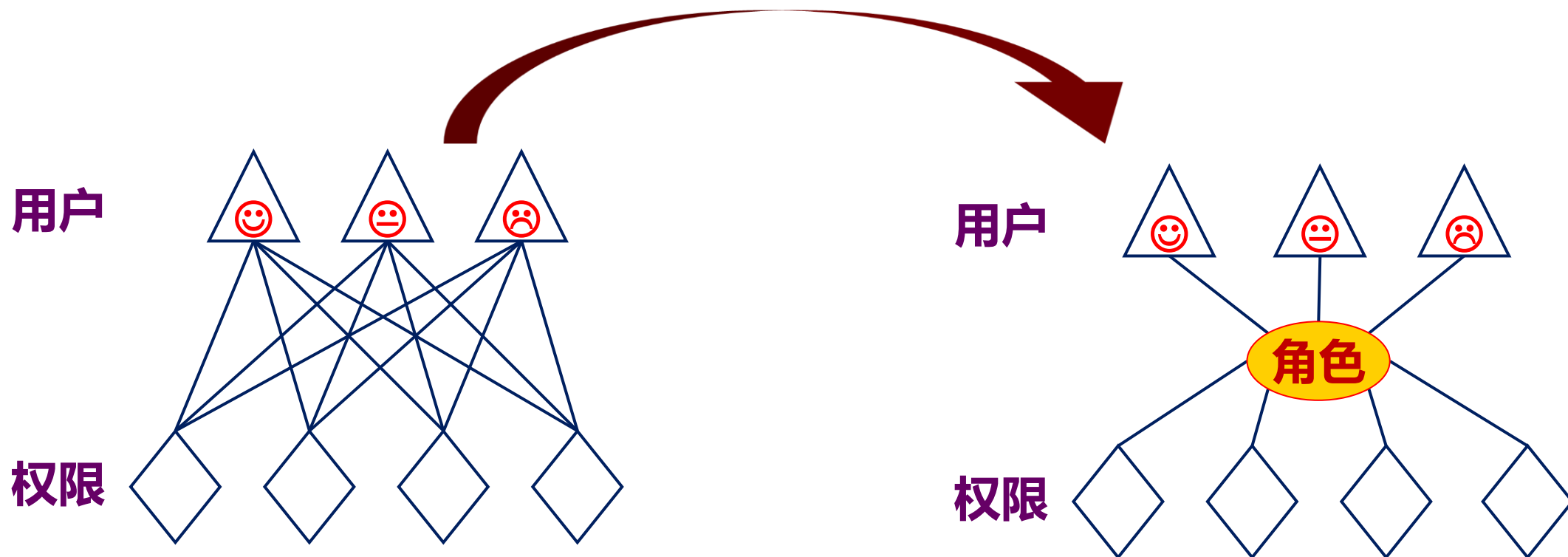
收回权限时，若该用户已将权限转授给其它用户，则也一并收回

grant select , insert **on** S **to** Liming **with grant option**

revoke insert **on** S **from** Liming

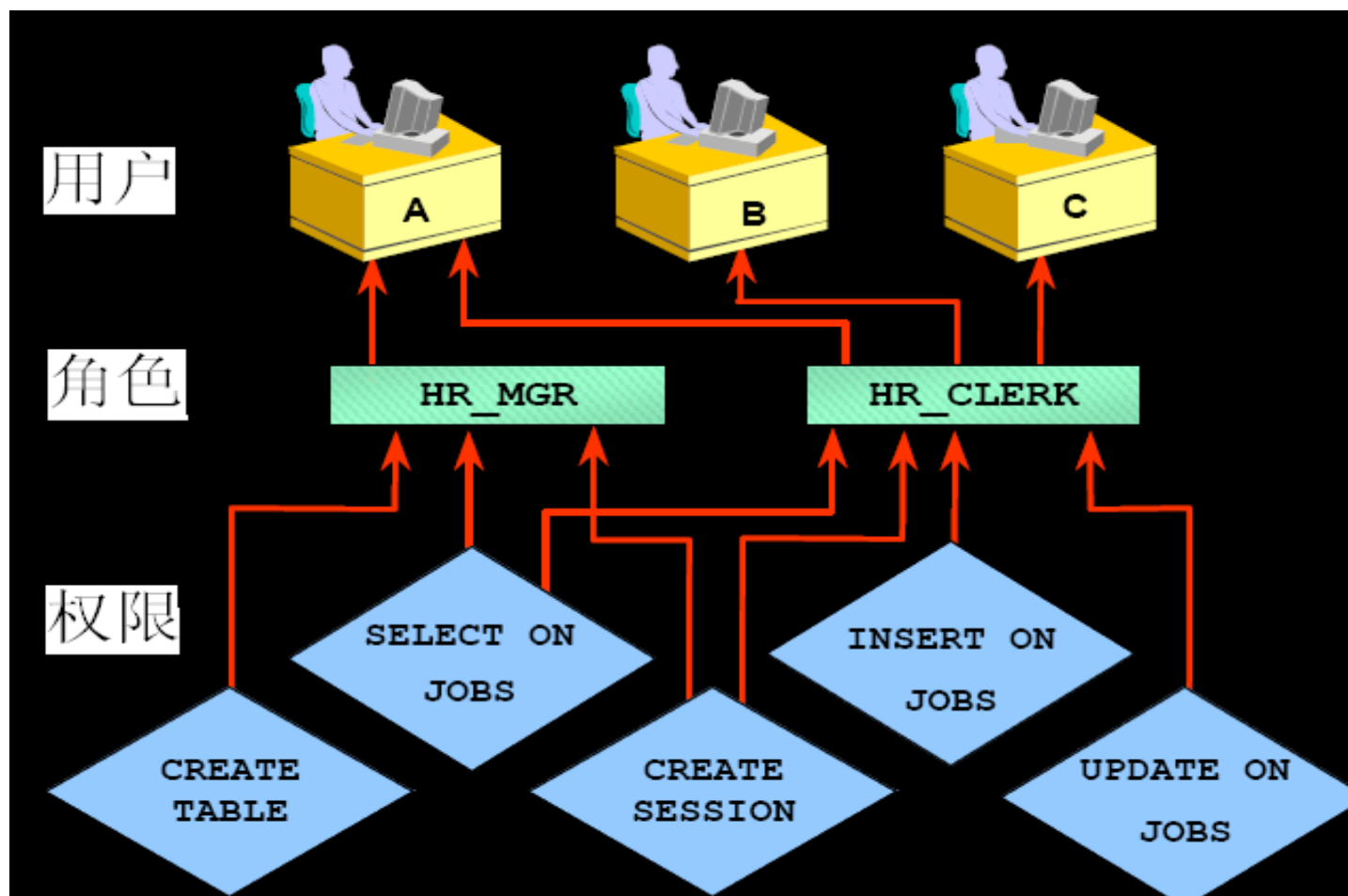
角色

- 角色是一组相关权限的结合，即将多个不同的权限集合在一起就形成了角色



角色

人事权



创建数据库角色: **create role** **role_name**

基于视图的安全性控制

授权Tom只有察看职工平均工资的权限

```
create view avg_sal  
as  
    ( select avg(sal)  
      from teacher )
```

```
grant SELECT on avg_sal to 'Tom'
```


利用当前用户实现行级精细存取控制

```
declare    @usr char(30)

set        @usr = user

select     'The current user is: ' + @usr
```

- 普通员工只能查看自己的记录
- 部门经理可以查看他所管理的员工
- 人力资源代表可以查看所有员工

```
select     *
from       student
where      sname = user
```

访问控制类型

自主访问控制 (DAC)

- 对客体拥有控制权的主体能够将该客体的访问权自主地授予其它主体，并在随后任何时刻将这些权限回收

强制访问控制 (MAC)

- 敏感度标记：绝密、机密、可信、公开
- 主体：许可证级别；客体：密级

保密性规则

- 下读：仅当主体许可证级别高于或等于客体密级时才能读取相应客体
- 上写：仅当主体许可证级别低于或等于客体密级时才能写相应客体

审计

- 审计就是对指定用户在数据库中的操作情况进行监控和记录，用以审查用户的相关活动（安全性）
 - 如数据被非授权用户删除，用户越权管理，权限管理不正确，用户获得不应有的系统权限等
-
- 审计就是监视和收集指定数据库的活动数据（调优）
 - 如哪些表经常被修改，用户共执行了多少次I/O操作等，为优化提供依据

审计：SQL Server

数据库审核规范

create database audit specification MyDBAudit

alter database audit specification MyDBAudit

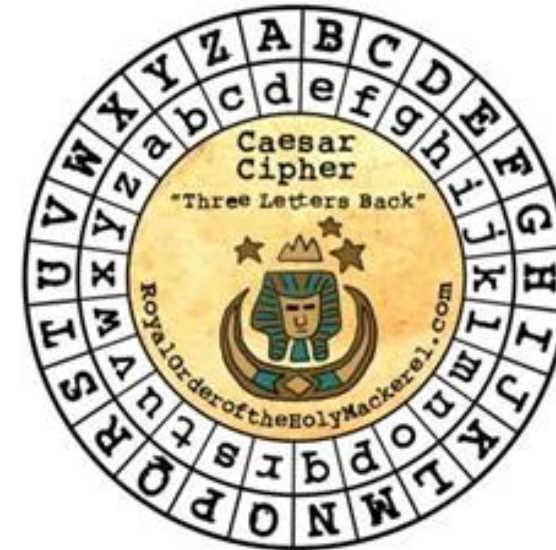
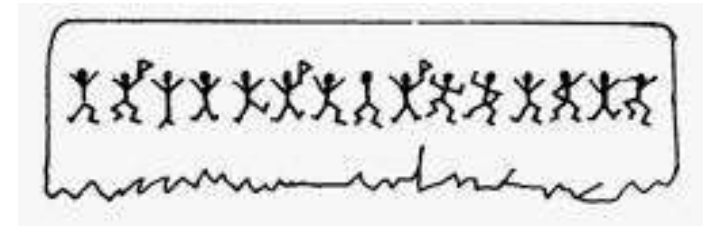
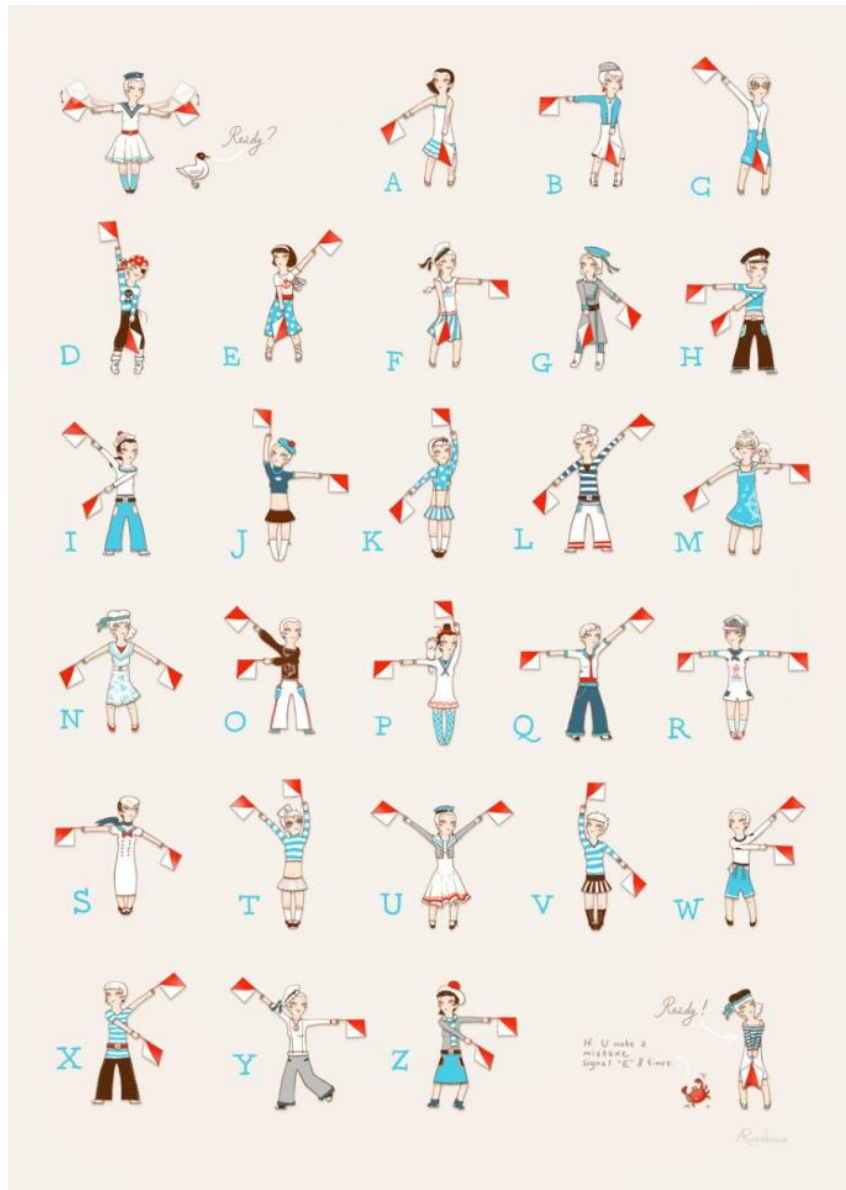
add (SELECT ON student)

查看审核历史

select event_time, succeeded, statement

from sys.fn_get_audit_file(...)

加密



短语加密

加密数据: **encryptByPassPhrase** ({ 'passphrase', 'cleartext'})

select **encryptByPassPhrase** ('hello', 'who am i')

0x0100000021D68E2E078E3EA6752239788B69D8B9BF1AD542A7C9774C9CAF66304F215F49

还原数据: **decryptByPassPhrase** ({ 'passphrase', 'ciphertext' })

select **decryptByPassPhrase** ('hello' ,

0x0100000021D68E2E078E3EA6752239788B69D8B9BF1AD542A7C9774C9CAF66304F215F49)

0x77686F20616D2069

非对称密钥加密

```
create asymmetric key myAsym_key
```

```
insert into emp(ename, salary) values ( 'tom',
```

```
    EncryptByAsymkey( Asymkey_ID( 'myAsym_key' ), 100000000) )
```

```
select          DecryptByAsymkey( Asymkey_ID( 'myAsym_key' ), salary )
```

```
from           emp
```

```
where          name = 'tom'
```

对称密钥加密

```
create symmetric key mySym_key
```

```
insert into emp(ename, salary) values ( 'tom' ,  
EncryptByKey( Key_GUID( 'mySym_key' ), 100000000 ) )
```

```
select DecryptByKey( Key_GUID( 'mySym_key' ), salary )  
from emp  
where name = 'tom'
```


SQL注入

认证过程发出的查询语句

```
select * from users  
where username = 'jake'  
      and PASSWORD = 'jakespasswd'
```

攻击者篡改这个SQL语句

```
select * from users  
where username = 'jake'  
      and ( PASSWORD = 'jakespasswd' or 'x' = 'x' )
```

资源控制：Oracle

PROFILE

➤CPU使用时间限制	CPU_PER_SESSION
➤逻辑读个数限制	LOGICAL_READS_PER_SESSION
➤用户会话限制	SESSION_PER_USER
➤会话空闲时间限制	IDLE_TIME
➤会话可持续时间限制	CONNECT_TIME
➤会话专用SGA空间限制	PRIVATE_SGA
➤口令限制	PASSWORD_LIFE_TIME
	PASSWORD_LOCK_TIME
	FAILED_LOGIN_ATTEMPTS

统计数据库安全性

要求：用户只能查询数据的**聚集值**，不能访问个体

漏洞一：个体太少

- 查询选修“古典哲学史” 的学生的平均成绩

漏洞二：多次查询，太多交叠

- Q_1 : 查询 n 个学生的总成绩为 x
- Q_2 : 查询 n 个学生 + A的总成绩为 y ，推出 A的总成绩为 $y-x$

统计数据库安全性

防范措施

- 查询引用的数据不能少于 n
- 两个查询的交不能多于 m

推出个体信息至少需要 $1 + \frac{n-2}{m}$ 次查询

Student(ID, GPA), ID从1到50

要求任何查询结果只能是一个聚集值，每次至少使用4条元组，任何两个查询的交不能大于2条元组。给出一个查询集合，使得能确定ID=9的GPA

隐私 保护

- 文明，是向拥有隐私权的社会不断迈进的进程
- 文明，是将一个人从一群人当中解放出来的进程
- 一九八四，数据监控：Big Data is Big Brother
- 中央数据银行：数据脚印整合， $1+1>2$
- 爱国者法案，国土安全法，万维信息触角
- 统一身份识别：驾照、护照、社会安全号



隐私保护数据挖掘：数据发布

Name	Age	Sex	Zipcode	Disease
Andy	5	M	12000	gastric ulcer
Bill	9	M	14000	dyspepsia
Ken	6	M	18000	pneumonia
Nash	8	M	19000	bronchitis
Joe	12	M	22000	pneumonia
Sam	19	M	24000	pneumonia
Linda	21	F	58000	flu
Jane	26	F	36000	gastritis
Sarah	28	F	37000	pneumonia
Mary	56	F	33000	flu



Age	Sex	Zipcode	Disease
5	M	12000	gastric ulcer
9	M	14000	dyspepsia
6	M	18000	pneumonia
8	M	19000	bronchitis
12	M	22000	pneumonia
19	M	24000	pneumonia
21	F	58000	flu
26	F	36000	gastritis
28	F	37000	pneumonia
56	F	33000	flu

连接推理

选民登记表

Name	Age	Sex	Zipcode
Andy	5	M	12000
Bill	9	M	14000
Ken	6	M	18000
Nash	8	M	19000
Mike	7	M	17000
Joe	12	M	22000
Sam	19	M	24000
Linda	21	F	58000
Jane	26	F	36000
Sarah	28	F	37000
Mary	56	F	33000

发布表

Age	Sex	Zipcode	Disease
5	M	12000	gastric ulcer
9	M	14000	dyspepsia
6	M	18000	pneumonia
8	M	19000	bronchitis
12	M	22000	pneumonia
19	M	24000	pneumonia
21	F	58000	flu
26	F	36000	gastritis
28	F	37000	pneumonia
56	F	33000	flu

87%的美国人口信息可以通过性别、出生日期、邮政编码进行个人重建

k-anonymity

有相同的准标识属性组(QI)的元组至少有k个(4-anonymous)

Age	Sex	Zipcode	Disease
[1, 10]	M	[10001, 15000]	gastric ulcer
[1, 10]	M	[10001, 15000]	dyspepsia
[1, 10]	M	[15001, 20000]	pneumonia
[1, 10]	M	[15001, 20000]	bronchitis
[11, 20]	M	[20001, 25000]	pneumonia
[11, 20]	M	[20001, 25000]	pneumonia
[21, 60]	F	[30000, 60000]	flu
[21, 60]	F	[30000, 60000]	gastritis
[21, 60]	F	[30000, 60000]	pneumonia
[21, 60]	F	[30000, 60000]	flu

我男朋友给他浇两次水我闺蜜
有时候就回回浇一次或者两次

然后我就按照他俩浇水的日期
查看我和我男朋友的聊天记录

发现我闺蜜回一次水的时候我
男朋友不是加班就是公司集体
活动

这种巧合也未免太明显了 😊

我就猜到他浇水2次就是问约吗

闺蜜回一次就是约

回两次就是不约



8 min
fat burn

HEART RATE

109 avg bpm



Start

© Jess - noveltysin/ Reddit

8:59